

Incident Response Plan

Status: Approved | Owner: [CISO / Compliance] | Version: 1.0 | Effective: [YYYY-MM-DD]

Note: This is a realistic sample, anonymized for testing. Replace bracketed items with your organization's details.

1. Purpose

Define a consistent lifecycle for detecting, responding to, and learning from security incidents at [Company] in line with SOC 2 CC7 and Privacy P1.5.

2. Scope

Covers incidents affecting confidentiality, integrity, availability, and privacy across all environments and vendors.

3. Roles & Team

Incident Response Team (IRT)

- IRT Lead (Security Manager)
- Comms Lead (PR/Leadership)
- Forensics (Security/Engineering)
- Legal & Privacy (General Counsel/DPO)
- Business Owner (Impacted app owner)

4. Severity & Classification

Levels

Sev 1 – Production outage/data breach; Sev 2 – Elevated risk with limited impact; Sev 3 – Contained event/false positive.

5. Lifecycle

5.1 Preparation

- Runbooks for common scenarios (credential leak, ransomware, vendor breach).
- Tools: EDR, SIEM, ticketing, comms channels (Slack bridge, email distro).

5.2 Detection & Analysis (CC7.2)

- Alerts triaged within 1 hour; capture indicators of compromise and affected assets.
- Preserve evidence snapshots and logs with chain of custody.

5.3 Containment

- Short-term: isolate accounts/hosts; network blocks.
- Long-term: patch vulnerabilities; rotate keys.

5.4 Eradication & Recovery

- Remove malware/artifacts; rebuild systems from gold images; validate via health checks.
- Monitor closely for 72 hours post-recovery.

5.5 Post-Incident Review (CC7.4)

- PIR within 5 business days; document root cause, corrective actions, and control improvements.

6. Notification & Communication

- Internal: Exec updates for Sev 1/2 within 2 hours.
- Customers: Notify per contract/SLAs.
- Regulators: If personal data involved, follow P1.5 timelines and counsel guidance.

7. Testing & Training

- Annual tabletop exercises for top-3 scenarios.
- Track action items to completion; update runbooks accordingly.

8. Metrics

- MTTD/MTTR; % PIRs completed on time; # of repeated incidents from same root cause.

9. Evidence & Records

- Ticket IDs; SIEM timelines; forensic notes; PIR report; customer comms templates.

10. Version History

Revision Log

v1.0 – Initial release [YYYY-MM-DD]

v1.1 – Added ransomware playbook [YYYY-MM-DD]

11. SOC 2 Mapping

CC7.1–CC7.4, CC2.3 (external comms), P1.5 (breach notification).